

TLP:CLEAR

INCIDENT REPORT

"Zloy": New Mamont Banking Trojan Infrastructure Posing as the "MAX" State Messenger and Fake Police Lockout Notices

Mamont • Android Banking Trojan • Telegram C2 • MaaS • Russia • Gosuslugi

Parameter	Value
Period	Active since at least May 2026, discovered 19 July 2026
Classification	Android banking trojan (Mamont family), SMS/push code theft, Telegram exfiltration
Threat level	HIGH
Attribution	Private "zloy" builder (Mamont variant), multi-tenant MaaS platform with separate "team" tenants
Target	Android users in Russia: major bank customers, the Gosuslugi government portal, messengers
Status	Campaign active; at least 112 related files and 3 C2 addresses at time of publication

1. Executive Summary

On 19 July 2026, routine monitoring of the public Triage sandbox sample stream surfaced an Android APK disguised as a video file using Greek homoglyphs in its filename ("Mqx_vid&eo.apk"). Automated classification could not attribute a malware family (family: none) — subsequent analysis showed this was due to a deliberate static-parser evasion technique built into the APK itself. Reverse engineering identified this as a new, previously undocumented variant of the well-known Russian Android banking trojan Mamont, built by a private builder that brands itself internally as "zloy".

Mamont is an Android banking trojan targeting Russian users exclusively; first documented in 2023, its activity has since grown sharply (per Kaspersky, 36x year-over-year, approaching one million affected devices in January–August 2025) despite the arrest of three suspected developers in Russia. The infrastructure discovered here shares no indicators with our previously published 15 March 2026 report on a Mamont campaign disguised as "accident photos" — this is a separate, self-contained cluster of the same family.

Key new technical findings: (1) a private "zloy" builder with a multi-tenant architecture — the malware carries a "team" field identifying which MaaS-platform tenant a given build belongs to; (2) a deliberate static-analysis evasion technique — the AndroidManifest.xml entry inside the APK's ZIP container has a spoofed "strong encryption" flag that breaks standard zip parsers (including those used by automated sandboxes), while Android's own parser ignores the flag; (3) stolen data is exfiltrated to Telegram across eight separate channels split by data type (SMS, push notifications, installed-app list, online status, etc.); (4) the lure impersonates Russia's state-backed messenger MAX (the real max.ru site is displayed as a decorative front over the malicious background service).

2. Discovery and static-analysis evasion

The sample was found while searching recent high-score Android samples lacking a family attribution. The first attempt to decode the APK with apktool and Python zipfile failed with a ZIP-parsing error. Byte-level analysis showed that the AndroidManifest.xml entry's local file header has the general-purpose "strong encryption" bit (bit 6) set and a spoofed compression-method field, while the corresponding central directory record — which the Android system parser relies on — remains valid and correctly describes ordinary unencrypted DEFLATE compression.

This is a classic anti-analysis trick: tools that strictly validate the local file header (apktool, standard zip libraries) refuse to read the manifest, while Android's own package parser reads from the central directory and does not cross-check it against the local header, so the APK installs without issue. After reconstructing a valid header from the central-directory data, the manifest and code decompiled normally, enabling the analysis below.

3. Target list and capabilities

The manifest explicitly lists the packages it checks for on the device via the Android 11+ package-visibility <queries> mechanism. The list includes mobile apps for Russia's largest banks, the government-services portal, and the main messaging apps:

- Banks: Sberbank, Alfa-Bank, Tinkoff, VTB, Sovcombank (Halva), Gazprombank, MTS Bank, Ozon Bank, Rosbank, OTP Bank.
- Gosuslugi (ru.gosuslugi.mobile) — a potential vector for stealing access to government services and associated two-factor authentication.
- Messengers: Telegram, VK, Odnoklassniki, and MAX (ru.oneme.app) — the Russian state-backed messenger promoted as a replacement for foreign services, and the exact app the lure itself impersonates.

The requested permissions and declared components give the malware full control of the device's SMS channel: intercepting incoming SMS (including acting as the default SMS app), reading and sending SMS, handling WAP Push, reading contacts and the phone number, and placing calls. It also registers a NotificationListenerService, which intercepts push notifications from any app — including one-time codes from banking apps — without needing SMS access at all. Its resources include an enabled "create a PIN code" screen — a classic overlay used to harvest a PIN/password under the guise of setting up the app itself.

Persistence relies on a broad set of broadcast receivers for boot, screen-unlock, and battery-optimization events — including receivers specifically for MIUI (Xiaomi), Huawei, Samsung, and Transsion power-saving events, indicating deliberate adaptation to device brands popular in Russia with aggressive background-process management.

4. The private "zloy" builder and MaaS architecture

All malicious functionality lives in a "zloy" namespace (packages `zloy.*`, `zloy.c2.*`, `zloy.core.*`), and the string resources explicitly carry a `zloy_build_id` value of the form "zloy-build-25626619" — indicating a private build tool likely used by more than a single operator.

Both the resources and the network protocol carry a "team" field (value "001" in the analyzed sample) transmitted during device registration with the C2. A public abuse report found afterward for a neighboring IP on the same hosting provider confirms this directly: it names a different team number ("Bombo"), a different operator handle ("Muertos 2.0"), and a different package name — meaning the same builder and the same hosting infrastructure serve at least two independent operators/tenants concurrently. This points to a malware-as-a-service model rather than a single self-contained project.

The C2 protocol runs over a WebSocket (`ws://`) connection with JSON messages of type `register/auth/evt/response`. Device registration is sent in the clear (`hwid`, `team`, device metadata) via an HTTP POST to `/api/v1/register`; the C2 responds with a session key encrypted under the build's static secret. All subsequent events (stolen data, status updates) are encrypted with that session key using AES-256-GCM before transmission. Larger files (e.g. SMS dumps) are uploaded via a separate HTTP endpoint, `/api/upload`, with `X-Team/X-Hwid` headers — confirming the multi-tenant model at the transport-protocol level as well.

The sample's string resources contain eight distinct Telegram chat identifiers, split by data type: an admin channel, an installed-app list, an archive, a launch channel, an online-status channel, push notifications, SMS push, and text-data. This matches the publicly documented Mamont pattern of exfiltrating stolen data directly to Telegram, which complicates network-level blocking since the traffic is indistinguishable from legitimate Telegram API use.

5. Infrastructure and distribution

All three discovered C2 addresses are hosted with a single provider — PLAY2GO INTERNATIONAL LIMITED (ASN 215439, registered in the UK, physically located in Frankfurt am Main, Germany). The 31.76.10.0/24 network block was registered on 3 June 2026 — the infrastructure is fresh. On VirusTotal, at least 112 unique files are associated with one of the addresses (31.76.10.34:8443), indicating an active, ongoing campaign rather than an isolated sample.

Distribution runs through disposable landing pages on the free Vercel hosting platform, themed around "police" (`police*.vercel.app`, including a subdomain with explicit Russian targeting, `"2026rupolice.vercel.app"`) — a typical social-engineering pretext in this fraud niche: "your account has been blocked by law enforcement, install this app to unblock it." Some files in the C2 cluster carry purely numeric filenames characteristic of Telegram file identifiers (`file_id`), indicating parallel distribution through Telegram channels/bots — the same channel used for exfiltration.

6. Indicators of Compromise (IOCs)

Values are defanged. Production-ready values are in the STIX 2.1 / MISP dumps.

Type	Value	Context
SHA256	`a30747b76e582410903566c8fd2e50c56cb469f267af99e847eced2040132328`	Max_video.apk, package ru.k6owy6.gzqak2x, C2 2[.]27[.]22[.]130:8443. Reverse-engineered by us.
SHA256	`ff79b21c3c2199a8375dfcfea02819a7e525133fd2593a02da4ee098dc8540ef`	base.apk, same cluster, C2 31[.]76[.]10[.]34:8443 (VirusTotal).
SHA256	`2be922ac1177689d3155fc2d1b9196facc790c520103b7280fe28066f7aac65f`	Another lure variant "Max_video.apk" (homoglyph spelling), same cluster.
Package	`ru.k6owy6.gzqak2x`	Analyzed build, team=001.
Package	`ru.mgpwm.ocz75i7`	Build for team=Bombo, operator "Muertos 2.0" (per a public abuse-report source).
C2 (ws/http)	`2[.]27[.]22[.]130:8443`	PLAY2GO INTERNATIONAL LIMITED (DE); C2 for the analyzed sample.
C2 (ws/http)	`31[.]76[.]10[.]34:8443`	PLAY2GO INTERNATIONAL LIMITED (DE); ≥112 files associated on VirusTotal.
C2 (ws/http)	`94[.]156[.]237[.]16:8443`	PLAY2GO INTERNATIONAL LIMITED (DE); named in a public abuse report (team Bombo).
ASN	AS215439	PLAY2GO-NET — PLAY2GO INTERNATIONAL LIMITED.
Domain (landing)	`2026rupolice[.]vercel[.]app`	Phishing landing with explicit Russian targeting, hosted on Vercel.
Domain (landing)	`police2206work[.]vercel[.]app`	Police-themed phishing landing, hosted on Vercel.
Domain (landing)	`policeonline2026[.]vercel[.]app`	Police-themed phishing landing (misspelled "online"), hosted on Vercel.
Domain (landing)	`policeonline2026[.]vercel[.]app`	Another spelling variant of the same landing.
Domain (landing)	`policecontrol2026[.]vercel[.]app`	Police-themed phishing landing, hosted on Vercel.

6.1. MITRE ATT&CK

- T1660 — Phishing (mobile vector)
- T1204.002 — User Execution: Malicious File
- T1406 — Obfuscated Files or Information (spoofed manifest ZIP flags)
- T1417 — Input Capture (PIN-gate overlay)
- T1517 — Access Notifications (NotificationListenerService)
- T1582 — SMS Control
- T1636.003 — Protected User Data: Contact List
- T1636.004 — Protected User Data: SMS Messages
- T1481.002 — Web Service: Bidirectional Communication
- T1646 — Exfiltration Over C2 Channel
- T1541 — Foreground Persistence
- T1624 — Event Triggered Execution

7. Recommendations

- Block the listed C2 addresses and the 31.76.10.0/24 subnet at network perimeters; report abuse to hosting provider PLAY2GO INTERNATIONAL LIMITED and to Vercel for the phishing subdomains.
- Banks on the target list should factor this cluster into fraud-pattern monitoring (sudden device change ahead of a transaction, timing correlated with receipt of a push/SMS code).
- Users should not install APKs outside official app stores from links sent via messengers or from callers claiming to be law enforcement or bank staff; official bank and MAX apps are distributed only through official stores.
- Operators of automated malware-analysis tooling should treat the described spoofed ZIP "strong encryption" local-header flag as an indicator of deliberate APK static-parser evasion.
- Given the multi-tenant nature of the "zloy" platform, expect further infrastructure clusters with different IPs/packages while retaining the same C2 protocol and Telegram exfiltration pattern.

TLP:CLEAR — This document may be distributed without restriction.